

AgentSQL

智 盾

使用手册

v0.2.0

<https://agentsql.cn>

发布候选

目录

1. 总览 /

2. 审计 /audit

筛选参数

导出

3. 演示台 /playground

静态评估：所有普通部署都有

Live Demo：仅 Demo 模式

4. Agent /agents

5. 数据源 /datasources

6. 权限 /policies

对象与动作

列级白名单

row_filter

7. 规则 /rules

内置规则目录

当前可编辑能力

阈值与动态依赖

8. 审批 /approvals

9. 脱敏 /mask-rules

10. 配置参考

server

store

defaults

theme

demo

环境变量

11. 运维操作

agentsqlctl 公开子命令

health

升级、回滚与备份

性能口径

12. 当前版本能力边界

AgentSQL 使用手册

发布状态：AgentSQL v0.2.0 即将发布。一键安装命令与 `ghcr.io/cuipengdba/agentsql` 镜像将在发布日可用；发布前可按本文「源码 / Live Demo」路径从本地构建体验。源码仓库为 `github.com/cuipengdba/agentsql`。

本手册按控制台真实菜单顺序说明 AgentSQL v0.2.0 的操作方式与能力边界。首次使用请先完成 [快速上手](#)；MCP 客户端配置见 [接入指南](#)。

1. 总览 /

总览把近期决策、趋势和实时事件集中在一页：

- `allow`：规则与策略允许，执行类请求可以进入受控执行。
- `deny`：被身份、权限或规则拦截，不触达业务 SQL 执行。
- `warn`：允许执行，但附带需要关注的告警。
- `approve`：转人工审批，SQL 不执行。
- `error`：解析、评估、存储或执行链路发生错误。



趋势图用于观察决策数量随时间变化；实时事件流通过 `GET /api/v1/stream` 使用 SSE 推送新审计事件。反向代理该路径时必须关闭缓存、响应压缩和 buffering，并把空闲超时设为大于 25 秒。
`server.event_stream_max_connections` 控制并发 SSE 连接上限。

注意：工具层前置拒绝可能尚未进入流水线，因此并非每一个失败都会出现在事件流或审计页。

2. 审计 /audit

审计页记录经过应用流水线的 SQL、对象、规则命中、决策、估算行数、返回行数、耗时与错误信息。它用于工程排障和行为追溯，不是法规级 WORM。

筛选参数

参数	含义
time_start / time_end	RFC3339 时间范围
agent_id	Agent ID
datasource_id	数据源 ID
session_id	调用会话 ID
mcp_tool	MCP 工具名
decisions	决策列表，逗号分隔
stmt_types	语句类型列表，逗号分隔
risk_min / risk_max	风险范围
keyword	SQL 或错误信息关键字
object	对象名

分页默认是 `page=1&page_size=20`，`page_size` 有效范围为 1–100。详情抽屉展示请求身份、SQL、对象、规则命中、各阶段耗时和最终决策，构成一次判断的证据链。

导出

导出沿用当前页面筛选条件，仅支持 NDJSON：

- `Content-Type: application/x-ndjson`
- 文件名：`agentsql-audit.jsonl`
- 单次上限：10000 条
- 超过上限：HTTP 422，需要缩小筛选范围

当前不支持 CSV 或 PDF。页面上的 PDF 按钮只显示“未来提供”提示，不会生成文件。

3. 演示台 /playground

演示台有两套不同能力，不能混为一谈。

静态评估：所有普通部署都有

`POST /api/v1/playground/assess` 只解析 SQL 并运行静态规则，不连接业务库、不执行 SQL、不写审计。六条内置样例是：

场景	预期
正常点查	<code>allow</code> ，无规则命中

场景	预期
无 WHERE 全表更新	deny, 命中 R002
堆叠注入	deny, 至少命中 R001、R006
pg_sleep 危险函数	deny, 命中 R007
有 WHERE、无 LIMIT 的 MySQL 批量写	approve, 命中 R202
残缺 SQL	error, 解析阶段 fail-closed

界面中的 `stageSamples` 仅用于展示 allow/deny/approve/warn/error 的流程样本，不是第三套可执行场景。

Live Demo: 仅 Demo 模式

`POST /api/v1/playground/run` 只在专用 Demo 模式注册。它使用固定合成数据源与演示身份，前五张卡会真实进入受控流水线，第六张是审计回看：

- 1. PostgreSQL 只读查询放行，返回不超过 5 行并写审计。
- 2. MySQL 无 `WHERE` 更新被 R002 与 Demo 只读屏障拒绝，不触库。
- 3. MySQL `phone`、`email` 结果脱敏。
- 4. PostgreSQL 大结果在 Demo 阈值下命中 R005，截断为最多 20 行。
- 5. 未授权 `internal_notes` 被 R010 拒绝。
- 6. 用最近 `audit_id` 查看审计详情，并跳到总览实时流。

普通生产部署没有 `/playground/run` 和 Live 控件。完整启动方法见 [DEMO.md](#)。

4. Agent `/agents`

Agent 是调用 AgentSQL 的独立身份。

字段	说明
<code>id</code>	唯一 ID
<code>name</code>	名称
<code>owner</code>	负责人
<code>level</code>	<code>readonly</code> 、 <code>dml</code> 或 <code>ddl</code>
<code>status</code>	<code>active</code> 或 <code>disabled</code>
<code>expires_at</code>	可选过期时间

能力档位：

- `readonly`：只允许查询。
- `dml`：允许查询与 `INSERT`、`UPDATE`、`DELETE`。
- `ddl`：包含 DDL 能力；具体 SQL 仍受策略与规则约束。

创建 Agent 时生成的 API Key 只展示一次。轮换 Key 后旧 Key 立即失效，不存在并行有效期。Agent 被禁用、过期、删除或轮换时，原 Key 都不能再通过认证。

不要把 `qps_per_agent` 理解为每个 Agent 的可编辑字段：它是全局默认值。连接上限 `conn_limit` 配在数据源上，也不是 Agent 字段。

控制台管理员登录 token 有效期为 12 小时；它与 Agent API Key 用途不同。

5. 数据源 `/datasources`

数据源保存业务库连接与执行上限。必须为 AgentSQL 创建独立最小权限数据库账号，禁止使用 `superuser`、`owner` 或 `root`。

字段	约束与默认值
<code>id</code>	必填，创建后不可修改
<code>name</code>	显示名称
<code>db_type</code>	<code>postgres</code> 或 <code>mysql</code>
<code>host</code>	数据库主机
<code>port</code>	1–65535；PostgreSQL 默认 5432，MySQL 默认 3306
<code>database</code>	数据库名
<code>username</code>	运行账号
<code>password</code>	新建必填；编辑留空保留原值；API 永不回显
<code>conn_limit</code>	默认 5，最小 1
<code>stmt_timeout_ms</code>	默认 5000
<code>row_limit</code>	默认 1000

保存后用「测试连接」验证。MySQL 驱动关闭 `multi-statements`；AgentSQL 本身也只接受单条 SQL。

TLS 边界：当前没有 SSL mode、CA、客户端证书、连接超时或 DSN 附加参数字段，不能宣称可在控制台完成数据库链路 TLS 校验。远程链路需要由部署网络与受控代理另行保障。

数据源密码使用 `AGENTSQL_SECRET` 加密。丢失或更换 SECRET 会导致已有密码无法解密；数据库/控制面备份与 SECRET 必须成对保存，详见 [部署指南](#)。

6. 权限 /policies

策略绑定一个 Agent 与一个数据源。默认无授权即拒绝；创建数据源和 Agent 并不自动授予任何表。

对象与动作

- 对象类型：database、schema、table、column。
- 动作：allow、deny。
- 合法对象名：*、schema.*、table、schema.table。
- 非法对象名：空值、首尾空格、多于一个点、空片段、*.x、*.*。

高危配置警告： * 与 schema.* 都是合法的整表全列授权，会让匹配表的列级白名单失效。不要把它们当作普通示例或便捷默认值。只有 *.* 与 *.x 属于非法写法。

database、schema、table 三种对象类型当前走同一套表模式匹配，没有独立的数据库层级或 schema 层级解析语义。

列级白名单

列级策略必须满足：

- 对象名精确到 table 或 schema.table。
- 不允许任何通配符。
- 至少填写一列。
- 动作只能是 allow。

列级白名单只在能够可靠归属单表投影列的范围内工作；JOIN 与自连接当前只做表级授权。

row_filter

row_filter 当前只会持久化和展示，决策引擎完全不使用它。它不是行级安全，本版本不要配置、不要宣传，也不能用它替代数据库 RLS 或安全视图。

7. 规则 /rules

内置规则目录

规则页的严重度使用 1（低）到 5（严重）；dynamic 表示需要 EXPLAIN、索引/表元数据或事务运行态等动态信息。

ID	标题	数据库	严重度	dynamic
R001	多语句堆叠防护	通用	5	否
R002	无条件批量写防护	通用	5	否
R003	只读 Agent 写操作防护	通用	5	否
R004	大范围扫描审批	通用	4	是
R005	大结果集限制提醒	通用	3	否（但告警实际依赖 EXPLAIN）
R006	注释与未知语句注入防护	通用	5	否
R007	危险函数黑名单	通用	5	否
R008	请求速率与并发限制	通用	5	否
R009	SQL 复杂度限制	通用	4	否
R010	越权表访问防护	通用	5	否
R101	高危 DROP 防护	PostgreSQL	5	否
R102	持重锁操作审批	PostgreSQL	4	否
R103	管理与文件函数防护	PostgreSQL	5	否
R104	COPY 外部程序防护	PostgreSQL	5	否
R105	无索引批量写审批	PostgreSQL	4	是
R106	大表结构变更审批	PostgreSQL	4	是
R107	长事务与空闲事务告警	PostgreSQL	3	是
R201	MySQL 文件读写防护	MySQL	5	否
R202	MySQL 危险批量写审批	MySQL	4	否
R203	MySQL 高危管理命令	MySQL	5	否
R204	MySQL 大事务审批	MySQL	4	是

标题、严重度和 `dynamic` 属性以 `web/src/constants/ruleMeta.ts` 为准。

当前可编辑能力

- 内置规则运行时只读取 `enabled`。控制台只能启用或停用，修改在下一次真实请求生效。
- 内置规则不能删除。
- 当前不提供运行时阈值、动作或风险分的编辑；“恢复默认”只是重新启用规则。
- 自定义规则支持 CRUD，字段为 `id`、`db_type`、`title`、`risk_level`、`pattern_type=ast`、`definition`、`enabled`。
- **自定义规则 ID 不会被装配进执行引擎。** 这只是配置记录能力，当前没有实际拦截效果。

阈值与动态依赖

内部阈值键包括：

- 通用： `max_scan_rows`、`row_limit`、`qps_per_agent`、`max_conns_per_datasource`、`max_sql_length`、`max_nesting_depth`、`max_union_count`。
- PostgreSQL： `large_table_rows`、`long_transaction_ms`、`idle_transaction_ms`。
- MySQL： `mysql_transaction_age_ms`、`mysql_transaction_affected_rows`。

这些阈值属于配置/运行时层，不在规则页编辑。当前公开严格 YAML 的 `defaults` 仅暴露 `row_limit`、`qps_per_agent`、`max_conns_per_datasource`，以及执行超时 `statement_timeout_ms`；其余名字虽然是引擎内部阈值键，但 `internal/config/config.go` 尚未暴露相应 YAML 字段。不要把未暴露键直接加入配置，否则严格解析会拒绝启动；公开配置入口需主控确认后再补。

动态规则依赖：R004 依赖 EXPLAIN；R105 依赖索引元数据；R106 依赖表行数；R107 与 R204 依赖事务运行态。

R005 特别说明：普通生产流水线把 R005 列入静态规则，但其大结果告警依赖的 EXPLAIN 动态阶段默认不运行，因此普通生产只保证执行层 `row_limit` 截断。Live Demo 的 R005 告警由 Demo 专用动态阶段产生，不能外推为生产保证；这是已知待修复项。

页面目录的 1-5 是规则严重度。流水线内部另有 `1=deny`、`2=approve`、`3=warn`、`4=info` 的决策优先级；两者不是同一个统一分值，不得混写。

8. 审批 /approvals

审批状态包括 `pending`、`approved`、`rejected`、`expired`。当前没有 TTL 或定时过期逻辑，`expired` 仅用于展示或种子数据。

管理员只能决定 `pending` 单。决定请求体是：

```
{
  "decision": "approve",
  "comment": "可选"
}
```

`decision` 只允许 `approve` 或 `reject`，保存后状态变为 `approved` 或 `rejected`。

核心语义：审批不是执行器，也不是豁免票据。 `approved` 只是一条人工决策记录，不会自动执行 SQL，也不会解锁或消费下一次 `execute_write`。“审批后自动执行”是未来版本能力。

工具层有两条路径：

- `execute_write` 返回 `decision:"approve"` 时，系统已经自动创建 `pending` 单并返回 `approval_id`，不要再调用 `request_approval`。
- 调用方主动希望先送审时，才使用 `request_approval`；它同样只建单、不执行。

调用方传入的 `reason` 当前只写日志；审批单保存的是规则评估原因。

9. 脱敏 /mask-rules

当前敏感类型只有 `phone`、`email`，算法只有 `mask`。脱敏按列在查询结果层执行，不修改数据库原值。

- 匹配键是最终结果列名的精确规范化值。
- `table_name` 是预留字段，当前不参与匹配。
- 全局规则可以不选择数据源；选择数据源时只在该数据源范围生效。
- 同一作用域与列名只能有一条规则。

复杂表达式、聚合、CAST、UNION、CTE、视图重命名等可能无法追溯源列。不要宣称任何别名都不可绕过；完整边界见末章。

10. 配置参考

配置文件使用严格 YAML：未知字段会导致启动失败。生成基础配置可使用 `agentsqlctl init-config`，生产细节见 [部署指南](#)。

server

字段	说明
<code>http_listen</code>	HTTP 监听地址，例如 <code>127.0.0.1:7780</code>
<code>console_enabled</code>	是否启用管理控制台；未显式配置时默认 <code>true</code>
<code>event_stream</code>	是否启用 SSE；未显式配置时默认 <code>true</code>
<code>event_stream_max_connections</code>	SSE 最大连接数，默认 100，有效范围 1–1000

store

`store.sqlite_path` 是 SQLite 简写，不能与 `store.metadata` 同时使用。

字段	说明
<code>sqlite_path</code>	默认 SQLite 控制面路径
<code>auto_migrate</code>	默认 <code>true</code> ； <code>false</code> 时只校验 schema 版本，不执行 DDL
<code>metadata.driver</code>	<code>sqlite</code> 或 <code>postgres</code> ，默认 <code>sqlite</code>

字段	说明
metadata.sqlite_path	metadata 使用 SQLite 时的路径
metadata.dsn	metadata 使用 PostgreSQL 时的 DSN
metadata.max_open_conns	默认 10
metadata.max_idle_conns	默认 5, 不能超过 open
metadata.conn_max_lifetime	默认 30m, 使用 Go duration 字符串
audit.separate	是否使用独立 audit 存储, 默认 false
audit.driver	独立 audit 当前只支持 postgres
audit.dsn	独立 audit PostgreSQL DSN
audit.max_open_conns	默认 10
audit.max_idle_conns	默认 5, 不能超过 open

defaults

字段	说明
statement_timeout_ms	全局默认语句超时, 不能为负; 模板值 5000
row_limit	全局默认结果行数上限; 模板值 1000
max_conns_per_datasource	全局默认数据源连接/并发上限; 模板值 5
qps_per_agent	全局默认每 Agent QPS 与突发上限; 模板值 20

规则内部还识别 `max_scan_rows`、`max_sql_length`、`max_nesting_depth`、`max_union_count`、`large_table_rows`、`long_transaction_ms`、`idle_transaction_ms`、`mysql_transaction_age_ms`、`mysql_transaction_affected_rows` 等阈值键, 但当前公开 `Config` 结构没有对应 YAML 字段, 状态为**待确认/未公开配置入口**。它们不能在规则页修改, 也不要直接加入严格 YAML。

theme

字段	说明
default	light 或 dark

demo

字段	说明
enabled	是否启用专用 Live Demo
banner	Demo 强制横幅; 空值使用固定默认文案
allowed_datasource_ids	启用时必须恰好是 ds-demo-pg 与 ds-demo-mysql
qps_per_agent	Demo QPS, 默认 2, 有效范围 1–5

字段	说明
anchor_date	可选, YYYY-MM-DD 真实日期

生产环境不要启用 `demo`。

环境变量

变量	用途
AGENTSQL_SECRET	必填, 恰好 32 字节; 加密数据源密码并派生管理员 token 签名密钥
AGENTSQL_ADMIN_USER	管理员用户名, 默认 <code>admin</code>
AGENTSQL_ADMIN_PASSWORD	控制台启用时必须填, 至少 12 字符且不能使用弱口令/公开示例
AGENTSQL_API_KEY	stdio 的 <code>--api-key</code> 替代; 优先用环境变量, 避免进入进程参数
AGENTSQL_STORE_METADATA_DSN	存在即覆盖 YAML metadata DSN, 包括显式空值
AGENTSQL_STORE_AUDIT_DSN	存在即覆盖 YAML audit DSN, 包括显式空值
AGENTSQL_INSECURE	仅本地测试允许公开示例凭据; 不关闭认证、安全规则或 fail-closed
AGENTSQL_DEMO	值为 <code>1</code> 时启用 Demo 模式
AGENTSQL_DEMO_RO_KEY	Demo 只读 Agent Key
AGENTSQL_DEMO_DML_KEY	Demo DML 拦截 Agent Key
LOG_LEVEL	日志级别
LOG_FORMAT	<code>json</code> (默认) 或 <code>console</code>

`AGENTSQL_DOWNLOAD_BASE` 仅供安装器下载源覆盖; `AGENTSQL_BENCH_DSN` 仅供 benchmark。两者都不是生产运行配置项。

11. 运维操作

agentsqlctl 公开子命令

子命令	用途
version	输出版本
init-config	生成默认配置
check-config	严格校验配置, 不创建 SQLite 目录
migrate	初始化或升级 metadata/audit schema
migrate-sqlite-to-postgres	把组合 SQLite 控制面迁移到 PostgreSQL
health	检查 HTTP 健康或直接检查控制面存储

子命令	用途
demo-seed	仅演示环境维护，用固定 manifest 写入 Demo 数据

不存在 `run-check-config-and-health` 子命令；该字符串只是迁移输出中的步骤文案。

health

两种模式互斥：

- `--url`：默认检查 `http://127.0.0.1:7780/healthz`，要求 HTTP 200 且 JSON `status:"ok"`。
- `--config` / `-c`：直接检查 metadata/audit 存储，输出 `metadata_driver`、`audit_driver`、`audit_separate`。
- `--timeout`：默认 3 秒。

```
# 适用前提：服务已在本机运行
agentsqlctl health --url http://127.0.0.1:7780/healthz --timeout 3s
```

```
# 适用前提：运行用户可读配置、SECRET 和对应控制面存储
agentsqlctl health --config /etc/agentsql/config.yaml --timeout 3s
```

升级、回滚与备份

升级器会做预检、备份和失败回滚；具体命令、服务状态检查和离线包流程见 [DEPLOY.md](#)。不要跳过外部备份确认。

备份铁律：**控制面数据库与生成其数据源密码密文的 `AGENTSQL_SECRET` 必须成对备份、成对恢复**。仅有数据库或仅有 SECRET 都不能恢复已有数据源密码。

SQLite → PostgreSQL 控制面迁移要点：停止旧服务写入；备份 SQLite 与 SECRET；准备 PostgreSQL metadata/audit 目标；运行 `migrate-sqlite-to-postgres` 并核对行数/哈希；切换运行账号 DSN；保留原 SECRET；运行 `check-config` 与 `health`；验证 `/readyz`、读、拒绝、审批和新审计 ID。完整步骤见 [DEPLOY.md](#)。

性能口径

当前归档的唯一对外基准口径是：内存 fake executor、20 worker、20 万样本，不包含数据库网络与执行时间，网关 CPU 路径 P99≈1.81ms。它不是端到端查询延迟；真实耗时还包括连接、EXPLAIN、数据库执行与审计存储。

12. 当前版本能力边界

- 默认无授权即拒绝；必须显式创建 Agent × 数据源策略。
- 缺 `reason`、用 `query` 发写语句、SQL 在工具层解析失败等前置拒绝发生在进入流水线之前，不保证每条失败都有审计。
- 自定义规则只做配置记录，不进入执行引擎；`row_filter` 只持久化和展示，不参与决策。
- 数据源没有 SSL mode、CA、客户端证书、连接超时或 DSN 附加参数字段。
- R005 的生产动态告警待修；普通生产只保证执行层 `row_limit` 截断，Live Demo 告警不能外推。
- 审批不会自动执行 SQL，也不是后续执行的豁免票据。
- 脱敏是结果层按最终列名匹配，不是完整 DLP。复杂表达式、聚合、CAST、UNION、CTE、视图重命名可能无法溯源；JOIN/自连接仅表级授权；`*/schema.*` 是整表全列授权；不承诺任何别名不可绕过。
- 审计是应用层记录，不是法规级 WORM，也不能防止 DBA 或其他高权限账号直连数据库。
- MCP 不是跨请求事务代理；一次请求只接受单条 SQL，不允许堆叠。
- 当前业务库仅支持 PostgreSQL 14–18 与 MySQL 8。不支持 Oracle、SQL Server、达梦、金仓、瀚高、GaussDB、OceanBase、TiDB。
- 当前不支持 SSO、LDAP、MFA、RBAC、WORM、SIEM、HA、Kubernetes、ARM 原生发布包、musl 或 CentOS 7 原生一键安装；这些均为后续路线。